Bài thực hành 05

Phân tích Tĩnh Nâng cao: SAT/SMT Solving

Hệ thống SecureSys – Module Auth + Access Control

Học phần CSE703093 – An toàn phần mềm
Phenikaa University

Ngày 8 tháng 7 năm 2026

Tóm tắt nội dung

Bài thực hành áp dụng **SMT solving** (Satisfiability Modulo Theories) bằng thư viện **Z3** để kiểm chứng tính **tương đương logic** giữa các cặp điều kiện chương trình (bản gốc và bản "tối ưu hóa"). Kỹ thuật này phát hiện các lỗi bảo mật tinh vi: off-by-one, backdoor bypass xác thực ẩn trong điều kiện được viết lại.

Mục lục

1 Kiến thức nền tảng **1**

2 Sáu cặp điều kiện được kiểm chứng **1**

3 Đối chiếu bằng liệt kê vét cạn (C) **2**

4 Kết quả kiểm thử tự động **2**

5 Tài liệu tham khảo **3**

1 Kiến thức nền tảng

Bài toán **SAT** (satisfiability): tồn tại một phép gán giá trị biến làm công thức boolean đúng hay không? **SMT** mở rộng SAT với các lý thuyết (theories) như số nguyên, mảng, ...

Kỹ thuật kiểm chứng tương đương logic:

$$P \equiv Q \iff \text{UNSAT}(P \oplus Q)$$

Nếu solver trả về UNSAT cho $(P \oplus Q)$ (XOR), P và Q **tương đương**. Nếu SAT, solver trả về một **phản ví dụ (counterexample)** – bộ giá trị cụ thể làm P và Q khác nhau.

2 Sáu cặp điều kiện được kiểm chứng

ID	Ngữ cảnh	Kỳ vọng	Kết quả Z3
COND-01	Điều kiện mở khóa cửa (De Morgan)	Tương đương	UNSAT – khớp
COND-02	Ngưỡng khóa tài khoản: >= 3 vs > 3	**Khác**	SAT tại `failed=3` – khớp
COND-03	PIN hợp lệ, đổi thứ tự AND	Tương đương	UNSAT – khớp
COND-04	`tamper -> alarm` viết lại	Tương đương	UNSAT – khớp
COND-05	Bypass xác thực cho admin	**Khác (backdoor)**	SAT – khớp
COND-06	Giới hạn số lượng mượn sách	Tương đương	UNSAT – khớp

Phản ví dụ nghiêm trọng nhất (COND-05): solver tìm ra bộ giá trị $\{\texttt{authenticated} = \text{False}, \texttt{is_admin} = \text{True}, \texttt{bypass_flag} = \text{True}\}$ làm điều kiện ”tối ưu” cho phép truy cập dù **chưa xác thực** – đây là lỗi **CWE-288 (Authentication Bypass Using an Alternate Path)**.

```
solver = Solver()
solver.add(Xor(P, Q))   # tim gia tri bien lam P va Q KHAC NHAU
result = solver.check()
is_equivalent = (result == unsat)
```

Listing 1: Kiểm chứng tương đương bằng Z3 (trích smt_equivalence_checker.py)

3 Đối chiếu bằng liệt kê vét cạn (C)

Với các điều kiện chỉ gồm biến boolean, `c/brute_force_checker.c` liệt kê toàn bộ 2^n tổ hợp và xác nhận kết quả **nhất quán tuyệt đối** với Z3. Với COND-02 (biến `Int`, miền vô hạn), liệt kê vét cạn **bất khả thi** – minh chứng trực tiếp giá trị của SMT solving.

4 Kết quả kiểm thử tự động

`tests/test_smt_verification.py` thực hiện 3 test: toàn bộ 6 cặp khớp kỳ vọng, phản ví dụ hợp lệ, và đối chiếu C/Z3 nhất quán. **Kết quả: 3/3 test PASS.**

Mục tiêu học tạp

- Hiểu bài toán SAT/SMT và kỹ thuật kiểm chứng tương đương UNSAT$(P \oplus Q)$.
- Dùng Z3 mã hóa điều kiện chương trình thành công thức SMT.
- Đọc hiểu và tận dụng phản ví dụ (counterexample) để debug.
- Nhận diện lỗi bảo mật qua kiểm chứng logic (off-by-one, backdoor).

Yêu cạu hoàn thiẹn

1. Bảng chân trị tự vẽ tay cho COND-01, COND-04.
2. Giải thích chi tiết lỗ hổng COND-05 kèm CWE tương ứng.
3. Cặp điều kiện COND-07 tự thêm và phân tích kết quả.

Yêu cạu kẹt quạ

`tests/test_smt_verification.py` toàn bộ 3 test PASS; kết quả brute-force (C) và SMT (Python/Z3) nhất quán tuyệt đối trên các điều kiện boolean.

5 Tài liệu tham khảo

- Đề cương CSE703093 – An toàn phần mềm, Chương 3 (3.1, 3.4).
- L. de Moura, N. Bjørner, *Z3: An Efficient SMT Solver*, TACAS 2008.
- CWE-288 – Authentication Bypass Using an Alternate Path or Channel.